2.5.2 Federated identity: the backbone of modern identity systems

In the federated model, one or more organizations, called *identity providers (IdPs)*, manage accounts, authentication, and identity attributes. Other organizations, called *relying parties (RP)*, rely on the IdPs for authentication and account services. For this to work, the interactions between the IdP and the RP are mediated by a protocol.

The common protocols used in federated identity systems include the Security Assertion Markup Language (SAML), OAuth, and OpenIDConnect (which is based on OAuth). The details of how these protocols work are beyond the scope of this book, but we will cover OAuth, which is a federated authorization protocol, more extensively in chapter 12. Each protocol describes the interactions between the IdP and RP to ensure a technically trustworthy exchange of assertions about authentication status and attributes.

Because federated identity allows identity information to be shared across multiple organizations, they rely on legal agreements called *trust frameworks* to say how the RP will use the data and what kind of guarantees the IdP provides.

For enterprise federation, the IdP is often sharing with the RP so that the RP can provide a service to the IdP. For example, an employer may act as the IdP for its benefits provider, the RP in this scenario, allowing employees to easily authenticate to the provider's system. SAML is the most commonly used protocol, and the agreements are usually bespoke legal contracts. In the case of the employer and benefits provider, they will have a well-defined legal relationship that establishes a trust framework for sharing identity data. You log in at the benefits provider, and your login credentials are used behind the scenes with your employer to authenticate you and return the attributes agreed to in the trust framework.

For online use cases such as single-sign-on (SSO) to a website, the IdP and RP usually lack a formal agreement. Instead, the RP has agreed to a click-through license that is the same for everyone. OAuth or OpenID Connect are the most common protocols in this situation. An example of this is when you